

NO RATE LIMIT ISSUE

INTRODUCTION

In cybersecurity, one of the most critical defenses against brute force and automated abuse is **rate limiting**. Many modern applications implement it to ensure that a user or system can only perform a limited number of actions within a specific time frame. When applications **lack proper rate limiting controls**, attackers can exploit this weakness to launch **credential stuffing, brute force attacks, API abuse, or even email bombing**. Understanding the importance of rate limiting and the risks of its absence is crucial for both developers and security professionals.

1. What is Rate Limit?

Rate limiting is a **security control that restricts the number of requests** a user or system can make to a server within a certain timeframe.

Example:

- Allowing only **5 login attempts per minute** for a user.
- Restricting API requests to **100 calls per hour**.

2. How does Rate Limiting work?

Rate limiting works by tracking user requests using identifiers such as:

- **IP address**
- **User account / session ID**
- **API keys / tokens**

If the number of requests exceeds the allowed threshold, the system may:

- Block further requests temporarily (throttling).
- Introduce delays.
- Return error codes like **429 Too Many Requests**.

3) What is No Rate Limit?

No Rate Limit occurs when **applications fail to restrict the number of user actions**, allowing attackers to perform unlimited requests without restriction.

Example:

- Unlimited login attempts → brute force attack.
- Unlimited OTP submissions → OTP brute force.
- Unlimited API calls → Denial of Service (DoS).

4) Impacts of No Rate Limit

- **Brute Force Attacks** – Attackers can guess usernames, passwords, or OTPs.
- **Credential Stuffing** – Automated testing of leaked credentials.
- **API Abuse** – Exploiting APIs for data scraping or service disruption.
- **Email / SMS Bombing** – Spamming a victim's inbox with thousands of messages.
- **Denial of Service (DoS)** – Flooding a system until it crashes.

5) No Rate Limit on Forgot Password → Email Bombing

If a “Forgot Password” functionality has no rate limit:

- An attacker enters a victim's email repeatedly.
- The server sends thousands of password reset emails to the victim's inbox.
- The inbox gets flooded (Email Bombing).
- This leads to **denial of service for the victim's email**, making it hard to find genuine emails.
- In some cases, it can also **distract the victim** while attackers attempt other malicious activities.

CONCLUSION

Rate limiting is a **critical security mechanism** that helps prevent brute force, credential stuffing, and service abuse. Applications without proper rate limits are highly vulnerable to automated attacks and exploitation. Developers should always implement rate limiting on sensitive endpoints like login, OTP, and password reset to ensure **robust protection against abuse**.